



Методическое пособие
по выполнению домашнего
задания курса
Внедрение и работа в DevSecOps

Изучить существующие CI/CD с точки зрения доступных инструментов ИБ

Описание

truffleHog

Ищет по репозиториям git пароли, ключи и другие чувствительные данные. Для идентификации секретов ищет строки с высокой энтропией, анализирует историю изменений кода и ветви.

Этот инструмент эффективен для поиска случайно сохранённых в исходном коде паролей и ключей, даже если впоследствии они были убраны.

Этот модуль пройдёт по всей истории изменений (комитов) каждой ветви и проверит каждое различие (diff) от каждого изменения кода и будет искать в них пароли и ключи. Поиск выполняется как по регулярным выражениям, так и с расчётом энтропии. Для проверок энтропии, truffleHog будет вычислять энтропию Шэннона (Shannon) для набора символов base64 и набора шестнадцатеричных символов для каждого фрагмента текста более длиной более 20 символов, состоящего из этих наборов символов в каждом diff (различии текста). Если на любой точке выявлена строка с высокой энтропией и длиной более 20 символов, то она будет выведена на экран.

Домашняя страница: <https://github.com/dxa4481/truffleHog>

Порядок выполнения

Для truffleHog нужен Python и устанавливается он с помощью Pip (система управления пакетами для Python).

Вы, конечно, можете проделать всё с помощью VM, но мы предлагаем вам рассмотреть возможность использования Docker Container'a в качестве "одноразовой машины".



Описание

Итак начнём:

1. Поскольку нам нужен Python, да ещё и с установленным менеджером пакетов Pip, то логично найти уже настроенный образ Python.

2. На момент написания данного ДЗ (2021г.) в DockerHub есть три ключевых группы образов: windowsservercore (нам не подходит), buster (на базе Debian Buster) и alpine (на базе Alpine). Мы будем использовать buster, поскольку он содержит уже привычный вам менеджер apt и всё остальное/

3. `docker run -it -p 8080:8080 python:buster /bin/bash` (зачем нам открывать порт, скоро узнаем)

4. После того, как вы попали в терминал контейнера, необходимо установить truffleHog: `pip install truffleHog` (обратите внимание на регистр)

5. Далее всё достаточно просто: указываем инструменту ссылку или путь к репозиторию. В нашем случае, мы воспользуемся специально подготовленным (Известное приложение WebGoat + дополнительные реалистичные кейсы, чтобы нельзя было поискать ответы в интернете:)) : https://github.com/OtusTeam/DevSecOps_secret-finding.git

Переходим по ссылке и кликаем на кнопке Code:

Важно: убедитесь, что вы выбрали именно HTTPS и скопировали ссылку.

6. Используйте следующую команду для запуска сканирования:

```
trufflehog repository | tee -a log.txt
```

где repository - https://github.com/OtusTeam/DevSecOps_secret-finding.git
Обратите внимание на регистр (да, это не опечатка, теперь hog написано маленькими буквами).



Описание

Вы увидите примерно следующий вывод:

Зелёным будет подсвечена мета-информация, а оранжевым - обнаруженный участок кода. В данном случае - это ложные срабатывания, поскольку это явно не "секреты", а checksum'ы зависимостей нашего проекта.

Повторно запустить лог на просмотр вы можете с помощью команды `cat log.txt | more` (выход по клавише q).

7. Также вы можете поставить с помощью apt (не забудьте про apt update) какой-нибудь текстовый редактор и проанализировать log.txt, но давайте посмотрим, как "забрать" файл из контейнера.

8. Сделать это можно двумя способами:

1) Через volume: `-v etc/test:opt/test`

2) В Python есть встроенный модуль HTTP-сервера, который запускает HTTP-сервер в текущем рабочем каталоге: `python -m http.server 8080`:

Так же можете попробовать с помощью nc.

Описание

Результаты выполнения:

Пришлите найденные вами "секреты" с описанием того, чтобы это могло быть (по вашему предположению).

Результаты выполнения

Пришлите ответ в виде аналитики, аналитика должна отвечать на вопросы:

- 1) Обозначение расположения секрета (файл/строка)
- 2) Ваши объяснение - почему найденное является секретом
- 3) Правильный способ хранения (по вашему предположению)

Максимальный балл по задаче можно получить найдя 5 разнотипных секретов (их гораздо больше, но многие из них повторяются, поэтому необходимо искать секреты различных типов).

Один найденный секрет - 1 балл (Максимум найдя секреты можно набрать 5 баллов)

Один найденный секрет - описание секрета -рекомендации по устранению - оценивается в 2 балла (здесь тоже максимум 2 балла).

Дополнительно:

*Изучите что такое BFG Repo-Cleaner и для чего он предназначен

** Как можно автоматизировать процесс поиска секретов и насколько это правильный подход?